
Audit de Conformite

Application SST DREETS BFC — Version 1.1.0

Confrontation du code implante (v1.1.0) avec la documentation PDF d'origine (Manuels Utilisateur et Superviseur, revision 1.0 — 28/02/2018) et la documentation interne (help.php, SPEC.md, CHANGELOG.md).

Date de l'audit : 10 juin 2026

Auditeur : Z.ai (analyse automatisee)

1. Synthese executive

L'audit de conformite compare les regles metier documentees dans les manuels PDF officiels (DIRECCTE Auvergne Rhone-Alpes, revision 1.0) avec l'implementation reelle du code PHP de l'application SST en version 1.1.0. Les corrections de securite et de confidentialite de la v1.1.0 (CHANGELOG.md) ont ete prises en compte comme etat actuel du code. La documentation interne help.php est utilisee comme reference complementaire car elle definit les permissions de chaque role de maniere plus detaillee que les PDF.

Categorie	Conforme	Non-conforme mineur	Non-conforme majeur
Confidentialite / acces aux signalements	4	1	1
Permissions par role (RBAC)	8	1	0
Fonctionnalites metier vs DB	2	0	0
Code mort / stubs / TODOs	3	0	0
Documentation interne	2	2	0
Total	19	4	1

Le code de la v1.1.0 est globalement conforme aux regles metier documentees. La seule non-conformite majeure concerne le bouton « Imprimer la fiche » visible par tous les roles dans report_card.php, alors que help.php reserve cette fonction au Superviseur uniquement. Les non-conformites mineures portent

sur le role Manager (acces en consultation auquel les PDF ne font pas reference) et la documentation interne SPEC.md qui n'a pas ete mise a jour pour la v1.1.0.

2. Methodologie

L'audit suit une methodologie en trois temps. Premierement, extraction des regles metier depuis les documents de reference : les deux manuels PDF (Manuel Utilisateur et Manuel Superviseur, tous les deux en revision 1.0 du 28/02/2018), la page help.php de l'application qui documente les 4 profils et leurs droits, et le CHANGELOG.md qui enregistre les modifications de la v1.1.0. Deuxiemement, analyse statique du code source PHP : lecture exhaustive des fichiers de requetes SQL, des pages de vue, des handlers de formulaire, des templates et du routeur. Troisiemement, confrontation systematique entre les regles documentees et l'implementation reelle, avec qualification de chaque ecart en conforme, non-conformite mineure ou non-conformite majeure.

Les deux manuels PDF sont quasiment identiques (meme structure, memes captures d'ecran). La regle cle est en page 8 : « Les profils Superviseurs et CHSCT auront acces aux signalements de l'ensemble des sites. » Cela implique que les agents n'ont acces qu'a leur site, et que seuls Superviseur et CHSCT voient tout. Le role Manager n'est pas mentionne dans les PDF.

3. Regles de confidentialite des signalements

3.1 Source PDF (Manuels DIRECCTE)

La documentation PDF est la source de reference primaire. Elle etablit deux regles fondamentales. Premierement, la page 8 des deux manuels indique : « Vous pouvez visualiser la liste des signalements pour chaque registre de votre site. Remarque : Les profils Superviseurs et CHSCT auront acces aux signalements de l'ensemble des sites. » Cette phrase definit implicitement que l'Agent voit uniquement les signalements de son site, et que seuls les Superviseurs et CHSCT ont une visibilite multi-sites. Deuxiemement, la page 10 precise : « Vous ne pourrez modifier que les signalements dont vous etes l'auteur (Et ceci quelque soit le registre). » La modification est donc reservee au declarant, quel que soit son role.

Le role « Manager » n'apparait nulle part dans les manuels PDF. Seuls trois roles y sont mentionnes : Agent, Superviseur et CHSCT. Le Manager est une addition de l'implementation qui n'a pas de correspondance directe dans la documentation d'origine.

3.2 Source help.php (Documentation interne)

La page help.php de l'application definit 4 profils avec des droits detailles. Elle complete la documentation PDF en precisant les permissions de chaque role, y compris le Manager qui y est decrit comme un « profil de consultation elargie » qui voit tous les sites, accede a la Synthese, aux Statistiques et a l'Export, mais ne peut pas repondre aux signalements ni gerer les utilisateurs. Le CHSCT a les memes droits de consultation que le Manager. La section « Confidentialite des signalements » dans help.php precise : « Le signalement est confidentiel. Seuls le declarant, les superviseurs et les membres du CHSCT peuvent y acceder selon leur role. Les managers ont egalement acces en consultation. »

3.3 Conformite du code (v1.1.0)

Regle	Source	Attendu	Code (v1.1.0)	Statut
Agent voit son site uniquement	PDF p.8 + help.php	Visibilite = site (default)	getAgentVisibility() retourne "site" par default	Conforme
Superviseur voit tous les sites	PDF p.8	canSeeAllSites() = true	canSeeAllSites() retourne true pour superviseur	Conforme
CHSCT voit tous les sites	PDF p.8	canSeeAllSites() = true	canSeeAllSites() retourne true pour chsct	Conforme
Manager voit tous les sites	help.php	Consultation elargie	canSeeAllSites() retourne true pour manager	Conforme
Option "all" retiree	help.php + securite	Plus d'option "tous" dans parametres	Seuls "site" et "own" dans settings.php	Conforme
canAccessReport() enforce	help.php	Verification dans view + print	Les deux pages appellent canAccessReport()	Conforme

3.4 Non-conformite majeure : bouton « Imprimer la fiche »

Le tableau des droits dans help.php (ligne 207-210) indique clairement que l'impression est reservee au Superviseur uniquement (croix rouge pour Agent, Manager et CHSCT). Or, dans le template report_card.php a la ligne 157, le bouton « Imprimer la fiche » est affiche sans aucune restriction de role. Il est visible par tout utilisateur ayant acces a la vue d'un signalement, y compris les agents, managers et membres CHSCT. La page report_print.php elle-meme verifie l'accès via canAccessReport(), ce qui est correct pour la confidentialite, mais ne limite pas l'impression au seul role Superviseur. Il s'agit d'une non-conformite majeure car elle contredit explicitement le tableau des droits documente dans help.php. Pour la corriger, il faudrait conditionner l'affichage du bouton a un role Superviseur dans report_card.php, et ajouter une verification de role dans report_print.php.

3.5 Non-conformite mineure : role Manager absent des PDF

Le role Manager n'existe pas dans la documentation PDF d'origine. Il a ete ajoute dans l'implementation et documente uniquement dans help.php. Ce n'est pas une erreur de code (le Manager a bien les permissions decrites dans help.php), mais c'est un ecart par rapport aux manuels officiels DIRECCTE. Si les PDF sont la reference contractuelle, le role Manager devrait etre officialise dans une mise a jour de la documentation utilisateur, ou a défaut, sa presence devrait etre signalee comme extension par rapport au cahier des charges initial. En l'etat, un auditeur externe referant aux seuls PDF considererait que ce role est hors perimetre.

4. Permissions par role (RBAC)

Cette section confronte systematiquement chaque permission documentee dans help.php avec l'implementation reelle du code PHP. Les verifications portent sur les fichiers de page (requireRole), les handlers, les templates et les fonctions d'accès.

Fonctionnalite	Agent	Superviseur	Manager	CHSCT	Code conforme ?
Creer un signalement	Oui	Oui	Oui	Oui	Conforme
Voir ses signalements	Oui	Oui	Oui	Oui	Conforme
Modifier (non traite)	Oui	Oui	Oui	Oui	Conforme
Voir tous les sites	Non	Oui	Oui	Oui	Conforme
Repondre	Non	Oui	Non	Non	Conforme
Abandonner	Non	Oui	Non	Non	Conforme
Imprimer	Non	Oui	Non	Non	Non-conforme
Synthese	Non	Oui	Oui	Oui	Conforme
Statistiques	Non	Oui	Oui	Oui	Conforme
Export	Non	Oui	Oui	Oui	Conforme
Gerer utilisateurs	Non	Oui	Non	Non	Conforme
Parametres	Non	Oui	Non	Non	Conforme

Sur 12 fonctionnalites testees, 11 sont conformes aux droits definis dans help.php. La seule non-conformite concerne l'impression, deja detaillee en section 3.4.

5. Fonctionnalites metier vs fonctions DB

L'audit precedent (v1.0.0) avait identifie deux fonctions DB sans interface utilisateur : `reactivateUser()` et `updateSite()`. Ces lacunes ont ete corrigees dans la v1.1.0.

Fonction DB	UI presente ?	Handler	Statut
<code>reactivateUser()</code>	Oui — users.php (bouton "Reactiver") + user_view.php	user_reactivate_handler.php	Conforme
<code>updateSite()</code>	Oui — settings.php (bouton "Modifier") + site_edit.php	site_edit_handler.php	Conforme

Les deux fonctionnalites manquantes de la v1.0.0 sont desormais completement implementees avec leur interface utilisateur, leur handler de formulaire et leur validation CSRF. Le handler de reactivation verifie que l'utilisateur est bien inactif avant de le reactiver, et le handler de modification de site verifie l'unicite du code et la presence des champs requis.

6. Code mort, stubs et TODOs

L'analyse statique du code source confirme que le nettoyage effectue en v1.1.0 est complet. Les trois fonctions orphelines identifiees dans l'audit precedent (`updateUserRole`, `updateUserSite`, `agentSeesOnlyOwn`) ont ete supprimees du code PHP et remplacees par `updateUser()` et `getAgentVisibility()`. Aucun fichier PHP ne reference plus ces fonctions supprimees. Aucun stub

alert("...a venir") n'existe dans le code. Aucun commentaire TODO, FIXME, HACK ou XXX n'a été trouvé. Le seul point résiduel est que le fichier SPEC.md (specification technique) référence encore updateUserRole() et updateUserSite() comme fonctions existantes, ce qui est une obsolescence documentaire et non un problème de code.

Element	Statut	Detail
alert("...a venir") stubs	Aucun trouve	Zero occurrence dans tout le code PHP
TODO / FIXME / HACK	Aucun trouve	Zero occurrence dans tout le code PHP
updateUserRole()	Supprime (v1.1.0)	Remplacee par updateUser() — aucun appel restant
updateUserSite()	Supprime (v1.1.0)	Remplacee par updateUser() — aucun appel restant
agentSeesOnlyOwn()	Supprime (v1.1.0)	Remplacee par getAgentVisibility() — aucun appel restant
mail.php "stub" (README)	Etiquette erronee	README.md ligne 74 qualifie mail.php de "stub" mais il contient 296 lignes de code SMTP complet

6.1 Non-conformite mineure : SPEC.md obsolete

Le fichier SPEC.md (specification technique v1.0) n'a pas été mis à jour pour la v1.1.0. Il contient toujours les références aux fonctions supprimées (updateUserRole, updateUserSite), indique que le Manager peut répondre aux signalements (alors que ce droit a été retiré en v1.1.0), et indique que l'abandon est réservé au déclarant (alors qu'il est désormais réservé au Superviseur). Ces inexactitudes dans SPEC.md sont des non-conformités mineures de documentation qui pourraient induire en erreur un développeur consultant la spec technique au lieu du code. Il est recommandé de mettre à jour SPEC.md pour refléter l'état réel du code v1.1.0, ou à défaut d'ajouter un avertissement en en-tête indiquant que ce document est antérieur aux corrections de sécurité.

7. Versionning et changelog

L'application dispose d'un fichier CHANGELOG.md qui documente les versions. La v1.0.0 (date du 2025-06-05) correspond à la première version, et la v1.1.0 (2026-06-10) documente détaillément les corrections de sécurité, les fonctionnalités ajoutées, le code mort supprimé et les modifications techniques. Le changelog est bien structuré avec des sections par type de changement (Sécurité, Fonctionnalités, Code mort, Documentation, Technique). Chaque entrée identifie les fichiers modifiés. Cette qualité de changelog est conforme aux bonnes pratiques.

Cependant, il n'existe pas de mécanisme de versionning automatique (git tags, semver dans composer.json, ou constante de version dans le code). La version n'est affichée nulle part dans l'interface utilisateur. Un utilisateur ne peut pas savoir quelle version de l'application il utilise sans consulter le fichier CHANGELOG.md sur le serveur. Il serait recommandé d'ajouter une constante APP_VERSION dans config.php et d'afficher la version dans le footer de l'application.

8. Recommandations

8.1 Priorite haute — Non-conformite majeure

Corriger le bouton « Imprimer la fiche » : dans templates/report_card.php, ligne 157, conditionner l'affichage du lien d'impression au role Superviseur uniquement. Ajouter egalement une verification de role dans report_print.php pour empecher l'accès direct par URL. Le code corrige serait :

```
if (in_array($userRole, ['superviseur'])): ... bouton Imprimer ... endif
```

8.2 Priorite moyenne — Non-conformites mineures

Mettre a jour SPEC.md : supprimer les references aux fonctions supprimees (updateUserRole, updateUserSite), corriger les permissions du Manager (pas de reponse), corriger l'abandon (reserve au Superviseur, pas au declarant). Ajouter un avertissement si une refonte complete est reportee.

Corriger README.md : remplacer le label « stub » pour mail.php par une description accurate (« Notifications email (client SMTP complet) »).

Officialiser le role Manager dans la documentation PDF : soit mettre a jour les manuels DIRECCTE pour inclure ce role, soit documenter explicitement qu'il s'agit d'une extension par rapport au cahier des charges initial.

8.3 Priorite basse — Ameliorations

Ajouter une constante de version : definir APP_VERSION = '1.1.0' dans config.php et l'afficher dans le footer. Cela permet aux utilisateurs et aux auditeurs d'identifier la version en cours sans acceder aux fichiers serveur.

Ajouter un avertissement dans help.php : mentionner que le role Manager est une extension par rapport aux manuels PDF d'origine, pour tracer cet ecart documentaire.

9. Tableau recapitulatif des constats

N.	Constat	Fichier(s)	Severite	Action
1	Bouton « Imprimer » visible par tous les roles	report_card.php:157, report_print.php	Majeure	Conditionner au role Superviseur
2	Role Manager absent des PDF officiels	Manuels PDF vs help.php	Mineure	Officialiser dans la doc ou documenter l'ecart
3	SPEC.md non mis a jour pour v1.1.0	SPEC.md:148, 351-353, 818-819	Mineure	Mettre a jour SPEC.md
4	README.md qualifie mail.php de "stub" a tort	README.md:74	Mineure	Corriger le label
5	Pas de version affichee dans l'UI	config.php, footer	Suggestion	Ajouter constante APP_VERSION

Fin du rapport d'audit. Les fichiers sources analyses sont disponibles dans le repertoire
/home/z/my-project/upload/sst_extracted/sst/. Les documents de reference PDF sont dans le meme repertoire :
DIRECCTE-SST-MANUEL-utilisateur (1).pdf et DIRECCTE-SST-MANUEL-Superviseur (1).pdf.